TLP:CLEAR

АНАЛИТИЧЕСКИЙ ОТЧЁТ

Кого DDoS-ят через TCP-отражение: наблюдения сенсорной сети, апрель–октябрь 2026

TCP SYN-ACK reflection | Спуфинг адресов | Кампания против российских организаций | Банки, провайдеры, ИТ

Параметр	Значение
Период наблюдения	**22 апреля — 12 октября 2026 (UTC)**
Дата анализа	**12 октября 2026**
Классификация	**TLP:CLEAR**
Тип активности	**DDoS: TCP SYN-ACK reflection (T1498.002)**
Уровень угрозы	**ВЫСОКИЙ**
Источник данных	**Сенсорная сеть в нескольких странах, включая Россию; conn-логи zeek за 180 дней, пассивный захват кадров**
Кампании	**Фоновый слой с 24 апреля (игровые и DDoS-protected хостинги, весь мир); российская кампания с 18 августа (22 организации за 8 недель)**
Крупнейшие жертвы	**Промсвязьбанк (31.08), Банк Уралсиб (29.09), Лукойл-Информ (05.10), Ростелеком и ГКУ «Мосгортелеком» (18–19.09), Яндекс (11.10), НБ «Траст» и VK Cloud (12.10)**
Атрибуция	**Источник по заголовкам не восстанавливается (спуфинг, рандомизация TTL/опций); публичных заявлений об ответственности не найдено**

1. Краткое заключение

С конца апреля 2026 года сенсорная сеть непрерывно регистрирует потоки TCP SYN с подделанными адресами источника — след DDoS-атак типа TCP SYN-ACK reflection. Подделанный адрес в таких пакетах — это адрес жертвы, поэтому по ним восстанавливается список целей, которых атакуют в данный момент. За 165 дней наблюдения такие потоки присутствовали в 130 днях.

Выделяются два слоя. Фоновый слой с апреля — классическая картина коммерческих booter-сервисов: цели — игровые и DDoS-protected хостинги по всему миру (Amarutu, ReliableSite, Amanah, DigitalOcean, Scaleway, WorldStream). Отдельная кампания с 18 августа 2026 направлена против российских организаций: провайдеров, банков, платёжных и ИТ-компаний, нефтяной отрасли — 22 организации за восемь недель.

Российская кампания ведётся одним инструментом и, по всей видимости, одним оператором: во всех волнах с августа по октябрь один и тот же пул TCP-отпечатков, одинаковая механика повторов и рандомизация заголовков. Её пакеты наблюдались только сенсорами, расположенными в России, — рефлекторы для неё подбираются внутри страны, и гео-фильтрация жертве не помогает.

Крупнейшие жертвы: Промсвязьбанк (31 августа, пик за весь период), Банк Уралсиб (29 сентября), Лукойл-Информ (5 октября), Ростелеком и ГКУ «Мосгортелеком» (18–19 сентября), 42 продакшн-балансировщика Яндекса (11 октября, 18:56–20:26 UTC), НБ «Траст» и VK Cloud (12 октября).

Источник атак по заголовкам не восстанавливается: адреса подделаны, TTL и опции TCP рандомизированы. Публичных заявлений об ответственности по этим целям не найдено. Профиль целей и сроки указывают на проукраинских хактивистов либо заказной DDoS; подтверждения нет. Адреса и операторы сенсоров в отчёте не раскрываются.

2. Метод наблюдения

Атака TCP SYN-ACK reflection устроена так: атакующий рассылает SYN-пакеты с подделанным адресом источника на множество хостов с открытыми TCP-портами; каждый хост отвечает SYN-ACK на подделанный адрес, и жертва получает поток SYN-ACK с тысяч легитимных серверов. Сенсор, на который попал такой пакет, видит жертву прямо в поле «источник». Сенсоры такие пакеты отбрасывают и ничего не отправляют по подделанному адресу, но полностью журналируют их через zeek, поэтому список целей восстанавливается без участия в атаке.

От фонового сканирования поток отражения отличается четырьмя признаками, и все четыре проверялись на каждой волне:

- Повтор одного и того же пакета. Сотни SYN с одинаковой четвёркой «источник, порт источника, цель, порт цели» за миллисекунды, с одинаковыми IP ID, seq и TCP timestamp. Настоящий стек так не делает: ретрансмиты идут с интервалом 1–3 с и с новыми номерами.
- Несовпадение TTL. На одной волне SYN «от» адреса жертвы приходил с TTL 17 или 30, а RST от настоящего хоста жертвы (ответ на SYN-ACK, прилетевшие к нему от рефлекторов) — с TTL 59. Пакеты шли с разных хостов и разными путями.
- Нереальный порт источника. Обычный клиент не открывает соединение с портов 80 или 443; в отражённых потоках против веб-фронтов это норма, потому что порт источника в подделанном SYN — это атакуемый порт жертвы.
- Жертва целиком. Адреса одной волны покрывают одну /24 или одну автономную систему (десятки хостов одной организации), а не случайный набор.

В zeek такой трафик даёт соединения с историей ShR или S0, orig_bytes = 0 и orig_pkts ≥ 3; на прикладном уровне ничего не происходит. Хронология строилась по 180-дневному архиву conn-логов всех сенсоров, атрибуция сетей — по RIPEstat, обратный DNS — по публичным резолверам. Подтверждение подделки адресов делалось пассивным захватом на уровне кадров во время живой волны 12 октября.

3. Хронология: два слоя

3.1. Фоновый слой (с 24–30 апреля, все сенсоры, порт-рефлектор в основном 23/tcp)

Короткие волны по 1–3 дня против одного хоста; жертвы — игровые серверы, VPN и DDoS-protected хостинги. Примеры: Amarutu Technology (NL) — один и тот же хост под атакой 95 дней подряд с июня по октябрь и второй хост 7–14 июля; ReliableSite (US) — июнь–август; Amanah Tech (CA) — 1–12 октября; DigitalOcean, Scaleway, WorldStream, Leaseweb UK, GigeNET, Oracle Cloud, RoEduNet (RO), WHG Hosting, Web Werks (IN), SpectraIP, Dedicated Telekomunikasyon (TR). Пик слоя — первая неделя мая.

3.2. Российская кампания (с 18 августа, только сенсоры в России, порт-рефлектор 3306/tcp)

Волны длиннее (1–3 дня), цели — целые автономные системы российских компаний, часто десятки хостов одной сети за раз. Порт-рефлектор другой, чем у фонового слоя: список рефлекторов для этой кампании строился отдельным сканированием российского адресного пространства. Между волнами паузы 1–9 дней. Профиль целей: банки (3), провайдеры и операторы связи (6), хостинг и ИТ (8), платёжная организация, логистика, нефтяная ИТ-компания.

Период	Жертва	AS	Сети-цели	Соединений
18–20.08	Омские кабельные сети	AS47165	109.120.20.0/24, 176.62.66.0/24, 176.62.67.0/24	≈1 700
20.08	СКБ Контур	AS49675	46.17.206.0/24	233
25.08	Selectel; СДЭК	AS49505; AS42524	92.53.101.0/24; 195.189.222.0/24	519; 27
26.08	Телепорт Телеком	AS39153	80.253.17.0/24, 80.253.21.0/24	344
27–29.08	Малнет	AS47156	213.5.24.0/24, 213.5.31.0/24	≈7 000
31.08	Промсвязьбанк	AS42231	91.223.63.0/24, 193.200.10.0/24	4 728 (пик)
02.09	GranLine	AS203806	195.209.48.0/24, 46.22.52.0/24	158
03.09	Necstel	AS61068	185.20.46.0/24, 185.9.79.0/24	426
07.09	НКО «Элекснет»	AS206973	91.225.194.0/23	2 267
08–09.09	ТИС Диалог (Калининград)	AS31214	83.219.130.0/24, 83.219.134.0/24, 83.219.149.0/24	>5 000*

18–19.09	Ростелеком; ГКУ «Мосгортелеком»	AS12389; AS8901	95.167.231.0/24; 212.11.158.0/24	≈5 000
25.09	Intek-Mytischi	AS57456	45.152.122.0/24, 31.135.94.0/24	491
26.09	Selectel (MSK), порт 443	AS50340	5.178.85.0/24	101
29.09, 01.10	Банк Уралсиб	AS21252, AS20872	193.109.114.0/24, 195.234.190.0/24	>5 000* + 410
02.10	Site LLC	AS30745	89.232.144.0/20	180
05.10	Лукойл-Информ	AS13105	95.171.229.0/24, 95.171.232.0/24	3 412
07.10	Masterhost	AS25532	90.156.201.0/24	1 121
08–09.10	EKMA IS	AS51518	91.217.78.0/23	1 414
11.10 18:56–20:26 UTC	Яндекс, 42 публичных VIP	AS13238	213.180.193.0/24, 213.180.204.0/24, 87.250.250.0/24, 87.250.251.0/24, 93.158.134.0/24, 5.45.196.0/24 и др.	1 321
12.10 (до 12:00 UTC)	НБ «Траст»; VK Cloud; VDSina (порт 443)	AS39850; AS47764; AS216071	194.226.143.0/24; 146.185.243.52; 91.84.104.0/24	≈1 100; S0 без RST; 142

«Соединений» — число соединений, учтённых одним сенсором; реальный объём атаки на жертву на порядки выше (тысячи рефлекторов). Звёздочкой отмечены волны, упёршиеся в лимит выгрузки.

4. Инструмент и оператор

Все волны российской кампании несут один и тот же набор признаков:

- Пул отпечатков TCP (JA4T). Доминирует 64240_2-4-8-1-3_1460_7 (линуксовый дефолт), рядом 29200_2-4-8-1-3_1460_7, 64240_2-1-3-1-1-4_1460_8, 65535_2-4-8-1-3_1460_9, 32120_2-1-1-4-1-3_1460_10. Тот же пул — от волны Ростелекома до волны «Траста». Значения правдоподобные (MSS 1410/1380/1400 типичны для VPN- и PPPoE-MTU): инструмент имитирует разнородных клиентов.
- Рандомизация заголовков. TTL у разных подделанных кортежей одной волны — 17, 30, 52 при одной и той же цели; окна 8192, 42300, 65535. Если бы слал один узел с фиксированным TTL, значения совпадали бы; 34–47 хопов в интернете не бывает. TTL выставляется случайно, дистанция до атакующего по нему не оценивается.
- Крафтинг raw-сокетом. Один и тот же пакет повторяется 84–107 раз за миллисекунды с одинаковыми IP ID, seq и TSval — так делает скрипт, а не ядро.
- Порт источника из списка целей. Класс порта меняется от волны к волне: Уралсиб — только высокие порты, Яндекс — только 80/443, EKMA — в основном ниже 1024, «Траст» — смесь.
- Рефлекторы внутри России. Пакеты кампании наблюдались только сенсорами в России; сенсоры в Европе и США видели лишь фоновый слой. Для жертвы это поток SYN-ACK с российских адресов, против которого гео-блокировка бесполезна.

- Инфраструктура атакующего. Подделка адресов требует аплинка без фильтрации источников (BCP 38) — это VPS или выделенный сервер у хостера без egress-фильтрации, а не домашний ботнет.

Фоновый слой использует те же приёмы (повторы, порт 23 как рефлектор), но другие списки рефлекторов и другие классы целей — вероятно, несколько независимых booter-сервисов.

5. Волна 11 октября: балансировщики Яндекса

11 октября с 18:56 до 20:26 UTC в поток отражения попали 42 публичных адреса продакшн-сервисов Яндекса: по обратному DNS это startup-balancer.stable.qloud-b, eats-superapp-authproxy.eda, ott-api-production-balancer.ott, external-hq-api.plus, core-renderer-staticapi.maps, external-promo.plus (все в домене yandex.net) и другие. Подделанные порты источника — 80 и 443, то есть атаковались HTTP/HTTPS-фронты. По механике волна ничем не отличается от волн против Уралсиба или «Траста»: тот же пул отпечатков, те же повторы, та же продолжительность порядка полутора часов.

6. Ограничения и атрибуция

- Адрес источника подделан по определению; TTL, окна и опции рандомизированы. Настоящий отправитель восстановим только трассировкой по аплинкам провайдеров.
- Объёмы в таблице — наблюдение одного рефлектора; они годятся для сравнения волн между собой, но не для оценки мощности атаки.
- Жертвы, чей стек не отвечает RST на непрошеный SYN-ACK (например, VK Cloud 12.10), видны только как S0 и в подсчётах по RSTO занижены.
- Открытые источники: публичный канал IT Army of Ukraine целей не публикует (раздаёт через собственный инструмент), мониторинг хактивистских и криминальных Telegram-каналов упоминаний этих жертв за период не дал, новостных сообщений об атаках на Уралсиб, Лукойл, «Траст» и Яндекс за эти даты нет. Профиль целей и сроки указывают на проукраинских хактивистов либо заказной DDoS; подтверждения нет.

7. Рекомендации

- Операторам сетей и хостерам: фильтрация подделанных источников на выходе (BCP 38 / uRPF). Без неё хостинг становится стартовой площадкой для подобных кампаний.
- Жертвам: поток SYN-ACK с тысяч разных адресов на порт 80/443 — это отражение, а не атака «от» этих адресов. Блокировать отправителей бессмысленно, гео-фильтр по России не поможет (рефлекторы российские). Работает фильтрация по состоянию соединения (SYN-ACK без предшествующего SYN отбрасывается на границе) и анти-DDoS с проверкой state.
- Владельцам открытых TCP-сервисов: ограничивать повторные SYN одного кортежа «источник, порт источника, порт назначения» (например, не более трёх за секунду) — легитимный клиент в такие лимиты не попадает, а отражение через ваш хост прекращается. Отдельно закрыть UDP-усилители (SNMP, DNS, NTP, memcached) или ограничить их per-source.
- Аналитикам: набор признаков из раздела 2 позволяет отличать отражение от разведки и не публиковать жертв как «сканеров» — ошибка, которую легко сделать по сырым логам.

8. Приложение: сигнатуры и данные

- zeek conn: conn_state ShR→RSTO или S0, orig_bytes = 0, orig_pkts ≥ 3, повтор кортежа (id.orig_h, id.orig_p, id.resp_p) не менее трёх раз за сутки. Полуоткрытые сканы (masscan, zmap) отсекаются условием orig_pkts ≥ 3 и отсутствием повторов кортежа.
- Подтверждение подделки на кадровом уровне: TTL входящего SYN не равен TTL RST того же адреса; одинаковый IP ID у серии SYN; межпакетный интервал 0 мс.
- Атрибуция: RIPEstat prefix-overview, PTR через публичные резолверы.
- MITRE ATT&CK: T1498.002 (Network DoS: Reflection Amplification), T1498 (Network Denial of Service), T1583.003 (Acquire Infrastructure: Virtual Private Server), T1595.001 (Active Scanning: Scanning IP Blocks — построение списка рефлекторов).

TLP:CLEAR — Этот документ может распространяться без ограничений.